

工程保证论证、证据与裁决规范

从设计主张到可审计 Assurance Case、Evidence Bundle 与发布决策

ESD-ASSURANCE-001

v2.0.0-draft.1

DRAFT / NORMATIVE DOMAIN

权威内容来源为 Markdown。本件仅供阅读与评审，未获正式发布批准。

阅读与版本说明

PREVIEW / DRAFT · 非权威阅读视图

本件保留源文档的标题、条款编号、版本与草案状态，不构成新的规范权威。封面、导航、索引与排版标签为生成内容，不能代替正文中的适用范围、条件或批准记录。

制品标识 ESD-ASSURANCE-001

版本 2.0.0-draft.1

状态 DRAFT / NORMATIVE DOMAIN

基准 commit a2195d9557f1c4e86b7f64c290844c63493b2f18

准备标识 c77a687ad6e68a5e1333fefb

使用方式 目录与书签可跳转；合订版中的核心文档链接跳转到本件对应篇章。独立版在源字节匹配时提供固定 **commit** 链接，否则指向随附的 **source** 快照。完整输入以准备记录为准，可能包含未提交变更；正文原有编号不重新连续编号。

ESD-ASSURANCE-001 v2.0.0-draft.1 DRAFT / NORMATIVE DOMAIN

目录

阅读与版本说明	2
工程保证论证、证据与裁决规范	5
1. 适用范围与非目标	6
2. 核心术语	7
3. 工程保证基本原则	7
4. Assurance Object 与身份	9
5. Claim Contract	11
6. Context、Assumption 与 Guarantee	13
7. Argument 结构	15
8. Defeater 与 Counterevidence	16
9. Evidence 分类	17
10. Evidence Quality Model	19
11. Evidence Envelope	20
12. 结果状态的严格区分	21
13. Evidence 生命周期与失效	23
14. Verification Plan	24
15. 工具与验证器可信度	26
16. 覆盖、代表性与采样	27
17. 组合保证	28
18. Assurance Case 充分性	29

19. Evidence Conclusion 与 Claim Status	30
20. Gate 与发布裁决	31
21. Release Evidence Bundle	32
22. Change Envelope	33
23. 运行时持续保证	34
24. Incident → Assurance Delta	36
25. Assurance Plane 元不变量	37
26. 角色与独立性	38
27. 常见反模式	38
28. Assurance Case 模板	40
29. Verification & Evidence Matrix 模板	41
30. Evidence Review Checklist	42
31. Release Evidence Bundle Manifest 示例	43
32. 最终判定标准	44

工程保证论证、证据与裁决规范

从设计主张到可审计 Assurance Case、Evidence Bundle 与发布决策

文档属性	内容
文档编号	ESD-ASSURANCE-001
版本	2.0.0-draft.1 (基于 1.0.0)
状态	DRAFT / NORMATIVE DOMAIN; 未获发布批准
规范角色	定义如何提出可裁决主张、组织论证、评价证据、处理反证并支持 Gate 决策
语义基础	ESD-METHOD-001 《优秀系统设计与工程保证方法论》
治理基础	ESD-GOV-001 《系统设计与工程保证治理及符合性规范》
执行参考	ESD-REFERENCE-001 《优秀系统设计：从约束、不变量到证据》
权威格式	本 Markdown 文件；PDF 与其他导出仅为阅读视图

规范目的

本文回答一个工程系统必须持续面对的问题：我们为什么有资格相信某项关键性质在当前制品、配置、环境、工作负载和故障范围内成立？它要求工程团队不仅提供测试结果，还要说明主张、假设、论证策略、证据质量、反证、覆盖边界、证据时效和最终裁决之间的关系。

摘要

工程保证不是“多写测试”的同义词，也不是对系统绝对正确性的承诺。它是一条受控推理链：

ESD-ASSURANCE-001-C01 · 原文代码 / 流程
Claim -> Context and Assumptions -> Argument -> Mechanisms -> Verification Activities -> Evidence -> Defeaters and Limitations -> Decision -> Runtime Revalidation

一份测试报告可能真实，却与当前二进制无关；一项形式证明可能严密，却只覆盖了抽象模型；一个生产指标可能代表真实流量，却无法证明未观测到的错误不存在。高质量 Assurance Case 的任务，是说明不同证据分别支持什么、不支持什么，它们如何组合，以及在什么变化后必须失效。

本规范明确区分四类经常被混淆的状态：

层次	示例状态
验证执行	PASS / FAIL / ERROR / SKIPPED
证据结论	SUPPORTS / CONTRADICTS / INCONCLUSIVE / NOT_APPLICABLE
证据生命周期	CURRENT / STALE / INVALIDATED / SUPERSEDED / NOT_REPRODUCIBLE
Gate 裁决	GO / CONDITIONAL_GO / NO_GO / UNKNOWN / NOT_APPLICABLE

这四层不得互相替代。测试命令退出码为零，不自动推出关键性质成立；证据当前有效，也不自动授权生产发布；Gate GO 只对声明的对象和 Change Envelope 有效。

1. 适用范围与非目标

1.1 适用范围

本规范适用于：

- R1–R3 系统和重大变更的关键性质论证；
- Architecture Review 和 Production Readiness 的证据评价；
- 发布、迁移、恢复、重放和安全变更的 Evidence Bundle；
- CI/CD 中产生的测试、分析、策略、构建和供应链证据；
- 生产指标、审计日志、演练结果和事故材料；
- AI/Agent、控制器和自动化系统的评估与运行证据；
- Assurance Plane 自身的规则、工具、例外和完整性证明。

1.2 非目标

本文不：

- 要求所有项目采用特定图形化 Assurance Case 语言；
- 宣称有限测试可以证明开放世界中的绝对无缺陷；
- 用单一分数取代对阻断性风险的判断；
- 规定具体测试框架、形式化工具或监控平台；
- 让证据 Reviewer 替代 System Owner 和 Decision Authority 的风险责任；
- 将自动验证扩展到它没有编码的属性。

2. 核心术语

术语	定义
Claim	关于特定对象、作用域和条件下应成立性质、具有明确验证义务的陈述
Top-level Claim	Assurance Case 最终试图支持的系统级结论
Subclaim	为支持上层 Claim 而分解出的较小主张
Context	解释 Claim、Argument 或 Evidence 含义所需的背景事实
Assumption	论证成立所依赖、可被证伪并可能失效的外部条件
Argument	说明 Evidence 与子主张为何足以支持 Claim 的推理结构
Strategy	对 Claim 的分解方式，例如按故障类别、边界、性质或运行模式分解
Evidence	能支持、反驳或限制 Claim 的可追溯事实或制品
Counterevidence	与 Claim 相冲突或削弱现有论证的证据
Defeater	若成立会使 Argument 失效或显著减弱的条件、反例或替代解释
Mechanism	系统中用于维持某项性质的控制、协议、约束或实现
Verification Activity	用于生成或评价 Evidence 的分析、测试、检查、证明或演练
Evidence Envelope	Evidence 所绑定的主体、环境、范围、版本、覆盖、限制和时效
Residual Risk	在当前控制和 Evidence 后仍被接受或保持未知的风险
Assurance Case	Claim、Argument、Evidence、Assumption、Defeater 和 Decision 的版本化结构
Evidence Bundle	为特定 Gate 或发布收集的不可混淆证据集合及清单
Decision-grade	Evidence 和 Argument 达到当前风险与裁决所需的质量，而非“证据很多”

3. 工程保证基本原则

ASSUR-REQ-001：主张必须具有类型匹配的验证义务

关键主张必须明确适用范围、成立前提、违反语义及与性质类型匹配的验证义务。Safety、有界活性、无界活性和统计 SLO 不得被强行套用同一种有限观测证伪规则，具体见 §5.2。以下表达不合格：

ESD-ASSURANCE-001-C02 · 原文代码 / 流程
系统足够可靠。 性能很好。 架构支持 <code>exactly-once</code> 。 系统是安全的。

合格表达至少包含：

ESD-ASSURANCE-001-C03 · 原文代码 / 流程

```
subject
property
scope
identity
temporal semantics
operating mode
assumptions
violation consequence
```

例如：

对同一 `source_object_version` 与 `pipeline_semantic_version`，在 NORMAL 和 RECOVERY 模式下，最多存在一个状态为 COMMITTED 的正式 completion manifest；并发重试、进程崩溃和 Kafka 重投递不得产生第二个不同结果。

ASSUR-REQ-002：主张、机制和证据必须分离

“系统使用事务”是机制，不是性质；“测试通过”是验证结果，不是系统主张；“线上三个月无事故”是观察，不是绝对证明。Assurance Case 必须分别表达这些层次。

ASSUR-REQ-003：Evidence 必须绑定具体对象

每份用于裁决的 Evidence 必须能够关联当前：

- 源代码或模型；
- 构建制品；
- 配置；
- Schema、策略、模型、DBC 或参考数据；
- 环境；
- 工作负载语料；
- 故障档案；
- 验证工具版本。

无法完成主体绑定的 Evidence 不能支持当前发布，只能作为背景信息。

ASSUR-REQ-004：负面证据不得被删除或隐藏

失败测试、事故、反例、已知缺陷、Reviewer 异议和生产异常都必须进入 Assurance Case。只收集支持性材料会形成确认偏差。

ASSUR-REQ-005：没有证据时保持未知

未执行、工具错误、证据过期、错绑、不可复现或覆盖不足必须产生 UNKNOWN / INCONCLUSIVE，不得转化为 PASS。

ASSUR-REQ-006：局部证据不能自动推出端到端性质

组件 A 和 B 各自通过不意味着 A→B 的边界、顺序、超时、容量和混合版本组合已被证明。组合保证必须显式论证。

ASSUR-REQ-007：Evidence 具有生命周期

证据必须有当前状态、失效条件和复审触发。证据不是一经产生永久有效的勋章。

ASSUR-REQ-008：裁决必须保留覆盖边界

任何 Gate 或发布结论必须说明：

- 支持到什么范围；
- 哪些情况未覆盖；
- 哪些 Assumption 尚未验证；
- 在什么变化后结论失效；
- 哪些 Residual Risk 被谁接受。

ASSUR-REQ-009：保证面自身必须 fail-closed

对 R2/R3 对象，Evidence 缺失、策略引擎不可用、验证执行异常或身份无法关联时，Assurance Plane 不得默认放行。

4. Assurance Object 与身份

4.1 Assurance Object

任何 Assurance Case 必须声明其对象，可能是：

- 系统或服务；
- 某个版本的组件；
- 架构决策；
- 数据迁移；
- 发布候选；
- 恢复能力；

- 运行模式；
- 权限和策略集合；
- 自动化门禁本身。

4.2 主体身份

最低身份结构：

ESD-ASSURANCE-001-C04 · 原文代码 / 流程

```
subject_identity:
  system_id: "...
  repository: "...
  source_commit: "...
  build_id: "...
  artifact_digest: "sha256:..."
  config_digest: "sha256:..."
  schema_or_policy_versions: []
  environment_id: "...
  deployment_target: "...
```

ASSUR-REQ-010：不能只用可变标签标识对象

latest、分支名、环境昵称或镜像 tag 不能作为唯一 Evidence 绑定依据。必须存在不可变 digest 或等价身份。

ASSUR-REQ-011：设计 Assurance 与发布 Assurance 必须区分

ESD-ASSURANCE-001-C05 · 原文代码 / 流程

Design Assurance

支持方案在声明假设下能够维护性质

Release Assurance

支持当前制品和配置在当前目标环境中具备放行资格

Operational Assurance

支持运行系统仍处于已验证边界内

三者可以共享 Evidence，但不能互相替代。

5. Claim Contract

5.1 最低字段

每项阻断级 Claim 至少包含：

ESD-ASSURANCE-001-C06 · 原文代码 / 流程

```
claim_id: "CLM-..."
property_id: "CP-..."
title: "..."
subject: "..."
claim_type:
"SAFETY|LIVENESS|DURABILITY|SECURITY|RESOURCE|SLO|RECOVERY|ASSURANCE_META"
scope:
  identities: []
  operations: []
  tenants_or_regions: []
  operating_modes: []
  versions: []
temporal_semantics: "always|eventually|within-window|statistical"
statement: "..."
assumptions: []
allowed_degradation: "..."
violation: "..."
verification_obligation: "..."
observation_limits: "..."
consequence: "..."
criticality: "BLOCKING|MAJOR|MINOR"
owner: "..."
review_triggers: []
```

5.2 Claim 类型

Safety Claim

说明“不允许发生什么”：

ESD-ASSURANCE-001-C07 · 原文代码 / 流程

同一业务身份不得出现两个互相冲突的正式提交。
未授权主体不得修改策略。
Partial result 不得被标记为 completed。

Liveness Claim

说明在明确 Assumption 下“最终会发生什么”：

ESD-ASSURANCE-001-C08 · 原文代码 / 流程
已接纳且依赖可用的任务最终进入 COMMITTED、QUARANTINED 或 FAILED_FINAL。

Liveness 必须声明公平性、依赖可用性、资源和时间假设，并区分：

性质	违反/支持义务	有限观测的边界
Safety	明确有限坏前缀或违反事件；在模型内可检查可达性	单个反例可反驳，未发现反例不等于全域证明
有界活性	在规定前提下定义起点、截止时间、完成 Oracle	超时可反驳对应有界 Claim
无界活性	形式化进展性质；论证公平调度、持续资源、依赖可用性与恢复进展	有限时间未完成不直接反驳“最终完成”；模型中的无限反例或进展证明须保留模型前提
SLO	明确统计总体、窗口、样本、估计方法及不确定性	不能从有限样本外推未覆盖流量与未来窗口

以上 Safety/Liveness 与公平性区分属于理论基础，参见 Lamport, *Specifying Systems*, 第 8–9 章；本套系的风险等级与裁决流程则是组织治理选择。

无界活性的运行告警只能表明进展风险或有界运营目标违反，不能自动冒充该无界命题的反证。需要可执行门禁时，应另立有界恢复/完成 Claim，而不是静默改写原命题。

验证方法的结论边界遵循 METHOD §3.1：模型检查与定理证明可在明确形式化范围内证明性质，不只是“没发现问题”；但需单独论证模型到实现的符合关系。

Durability / Recovery Claim

说明在指定故障集合内哪些事实保持可恢复、多久恢复以及从哪个权威源恢复。

Resource Claim

说明资源硬上界和过载行为，而不是只给平均利用率。

SLO Claim

说明统计窗口、流量范围、排除项和测量方法。SLO 不能替代硬正确性 Claim。

Assurance Meta-claim

说明证据、门禁或身份链自身不会被静默绕过，例如：

ESD-ASSURANCE-001-C09 · 原文代码 / 流程

缺失或过期证据不得被解释为 PASS。

ASSUR-REQ-012: Claim 必须有作用域

没有版本、身份、模式、租户、区域或时间范围的全局 Claim 默认不具备可裁决性。

ASSUR-REQ-013: Claim 必须有违反定义

必须按 §5.2 说明 Claim 的违反语义、可用反证、支持性论证和观测限制。无界活性需进展与假设论证，不能要求有限“尚未完成”作为反证；SLO 需统计判据。运行时不可直接检测的部分必须登记补充验证方法、Owner 与剩余未知。

6. Context、Assumption 与 Guarantee

6.1 Context

Context 是定义域事实，例如：

- Kafka 为 at-least-once delivery；
- 单对象硬上限为 40 MiB；
- DBC Registry 版本不可变；
- 生产节点规格为某 CPU/内存组合。

Context 不应被用于掩盖未验证 Assumption。

6.2 Assumption

每个关键 Assumption 至少包含：

ESD-ASSURANCE-001-C10 · 原文代码 / 流程

```
assumption_id: "ASM-..."
statement: "..."
owner: "..."
validation_method: "..."
runtime_signal: "..."
valid_range: "..."
expiry_or_review_trigger: "..."
violation_response: "..."
validation_status: "UNVALIDATED|VALIDATED|VIOLATED|UNKNOWN"
```

ESD-ASSURANCE-001-C10 · 续

```
lifecycle_status: "PROPOSED|ACTIVE|EXPIRED|RETIRED"  
monitoring_status: "MONITORED|UNMONITORED|UNAVAILABLE|NOT_APPLICABLE"  
risk_flag: "NONE|AT_RISK"  
evidence_refs: []  
last_validated_at: "..."  
supersedes: []
```

以上为 Assumption 字段的唯一受控定义；METHOD 与 REFERENCE 只摘要引用，不另建状态机。四个维度独立：

- validation_status 表示未验证、证据支持、已知违反或无法判断；必须保留证据和作用域。
- lifecycle_status 表示提出、使用中、有效期结束或退役；到期不是事实违反。
- monitoring_status 表示当前有监测、未配置、监测不可用或经论证无需运行监测；后者仍需复审机制。
- risk_flag 是预警标记，AT_RISK 不自动改变验证结论。

迁移旧单字段时，VALIDATED/UNVALIDATED/VIOLATED/UNKNOWN 进入验证维度，PROPOSED/EXPIRED/RETIRED 进入生命周期，MONITORED 进入监测维度，AT_RISK 进入风险维度。其他维度须根据原始记录补齐，不能默认“已验证”。旧 INVALIDATED 必须人工区分事实违反、支持证据失效或假设被替换；旧 REPLACED 以旧记录 RETIRED 加新 ID / supersedes 表达。

证据不足或过期时重评验证状态；仍有适用反证则保留 VIOLATED，不得借过期、风险接受或退役把已知违反改写为未知。依赖 Claim 按 §19 重评。

ASSUR-REQ-014：关键 Assumption 必须可监测或可复审

若性质依赖某个外部条件，而系统既不验证、也不监测、也无复审触发，则该 Assumption 形成 Epistemic Debt。对阻断级 Claim，这通常导致 UNKNOWN。

6.3 Assume–Guarantee

边界契约应表达：

ESD-ASSURANCE-001-C11 · 原文代码 / 流程

```
If Assumptions(A) hold,  
component A Guarantees G(A).  
  
Consumer B may rely on G(A)  
only if G(A) satisfies Assumptions(B).
```

边界必须覆盖：

- 成功结果；
- 错误和超时；
- 重复和乱序；
- 容量和背压；

- 版本兼容；
- 降级与恢复模式。

ASSUR-REQ-015：上游 Guarantee 必须满足下游 Assumption

仅仅“接口字段相同”不足以证明组合成立。时序、容量、重试、可见性和错误语义也必须匹配。

7. Argument 结构

7.1 标准结构

ESD-ASSURANCE-001-C12 · 原文代码 / 流程
Top-level Claim supported by Strategy -> Subclaim 1 -> Evidence A, B -> Subclaim 2 -> Evidence C -> Subclaim 3 -> Evidence D, E constrained by Context dependent on Assumptions challenged by Defeaters / Counterevidence

7.2 常用分解策略

Strategy	适用场景
按关键性质	Safety、Liveness、Durability、Security 分解
按状态转换	CREATE、PROCESS、COMMIT、ACK、RECOVER 分解
按故障类别	crash、timeout、partition、resource exhaustion、operator error
按边界	producer、broker、worker、store、consumer
按运行模式	NORMAL、DEGRADED、DRAINING、RECOVERY、EMERGENCY
按租户/区域	多租户隔离、多区域故障域
按生命周期	build、deploy、operate、migrate、retire

ASSUR-REQ-016：分解必须保持完整性

分解后必须说明为什么所有子 Claim 共同足以支持上层 Claim。不能只列出一组测试名称而没有覆盖论证。

7.3 Argument Sufficiency

论证充分性至少检查：

- Claim 是否定义清楚；
- Assumption 是否可接受；
- Strategy 是否遗漏关键状态或故障；
- Evidence 是否与 Claim 相关；
- 证据是否代表目标环境；
- Counterevidence 是否已处理；
- 组合边界是否成立；
- 剩余未知是否在授权范围内。

ASSUR-REQ-017：不得用数量替代充分性

更多测试、更多页面或更高覆盖率不能自动弥补一个未覆盖的阻断级提交窗口、权限边界或恢复路径。

8. Defeater 与 Counterevidence

8.1 Defeater 类型

类型	示例
适用性 Defeater	测试环境不是生产架构
身份 Defeater	Evidence 来自旧 commit
覆盖 Defeater	未覆盖写成功但超时的结果未知窗口
代表性 Defeater	基准只使用小对象和干净数据
工具 Defeater	静态分析器对相关语言特性不支持
组合 Defeater	A/B 单独通过，但 mixed-version 边界未测试
运行 Defeater	输入分布已经超出验证范围
组织 Defeater	手工步骤无稳定 Owner，无法重复执行

8.2 Defeater Register

ESD-ASSURANCE-001-C13 · 原文代码 / 流程

```
defeater_id: "DFT-..."
related_claims: []
statement: "..."
source: "review|incident|test|runtime|assumption"
severity: "BLOCKING|MAJOR|MINOR"
status: "OPEN|MITIGATED|ACCEPTED|REFUTED|CLOSED"
owner: "..."
resolution_evidence: []
review_trigger: "..."
```

ASSUR-REQ-018： 阻断级 Defeater 未解决时不得给出支持性结论

对阻断级 Claim，如果存在尚未反驳或缓解的阻断级 Defeater，Evidence Conclusion 必须为 INCONCLUSIVE 或 CONTRADICTS。

ASSUR-REQ-019： Counterevidence 与支持性 Evidence 同等保留

不得删除失败报告、异常样本或 Reviewer 异议以“清理”发布包。关闭它们必须保留修复和重新验证链路。

9. Evidence 分类

9.1 Evidence 类型

类型	示例	主要优势	常见边界
DESIGN	ADR、协议说明、状态机	解释意图与语义	不能证明实现符合
STATIC	类型检查、lint、静态分析、 依赖扫描	可重复、覆盖广	仅检查已建模规则
FORMAL	模型检查、定理证明、协议 验证	对模型范围内强	抽象与实现映射可能不足
UNIT	单元测试、单元级 mutation 测试	快、可定位	环境与组合覆盖有限
PROPERTY	属性生成、性质驱动测试	探索输入与不变量	受生成器、Oracle 与采样范围 限制
INTEGRATION	跨组件契约和故障测试	验证边界	语料和环境仍可能不代表生产
SYSTEM	端到端、性能、恢复、soak	代表真实组合	成本高、覆盖仍有限

类型	示例	主要优势	常见边界
SECURITY	threat model、SAST/DAST、渗透、权限审计	关注攻击面	时效和环境敏感
OPERATIONAL	SLI、审计、生产 invariant、事件	真实运行事实	缺少反事实，未观测不等于不存在
RECOVERY	restore、replay、DR、game day	验证恢复能力	需与生产规模和依赖匹配
REVIEW	专家评审、独立挑战	发现未编码风险	主观、需记录依据
PROVENANCE	构建证明、签名、digest、SBOM	建立对象身份链	不证明业务语义正确

本表是 `evidence_type` 的唯一受控枚举，§11.1 必须与之一致。每份 Evidence 选一个主要类型；其他方法用 tags 或独立 Evidence 记录。旧值 UNIT/PROPERTY 按实际活动明确迁移为 UNIT 或 PROPERTY，无法区分时要求人工复审；未知值属于记录验证错误，不得静默映射为任意已知类型。

ASSUR-REQ-020：阻断级 Claim 应使用证据多样性

对 R2/R3 阻断级 Claim，原则上不应只依赖单一类型 Evidence。至少应组合：

- 设计/语义 Evidence；
- 实现或动态 Verification；
- 对目标环境具有代表性的系统/运行 Evidence；
- 必要时的独立 Review。

无法满足时必须记录理由和剩余风险。

9.2 Evidence 不是装饰

每份 Evidence 必须回答：

1. 它支持或反驳哪个 Claim？
2. 它检查了什么机制或场景？
3. 它绑定哪个对象？
4. 它在什么环境和输入下产生？
5. 结果是什么？
6. 哪些情况未覆盖？
7. 何时失效？

10. Evidence Quality Model

10.1 质量维度

每份关键 Evidence 至少按以下维度评价：

维度	关键问题
Relevance	与 Claim 的逻辑关系是否直接？
Validity	方法是否真正测量了声称测量的性质？
Provenance	来源、生成过程和责任主体是否清楚？
Subject Binding	是否绑定当前制品、配置和环境？
Reproducibility	能否在受控条件下重新产生？
Representativeness	语料、负载和环境是否代表目标使用？
Coverage	覆盖了哪些状态、故障、版本和边界？
Freshness	当前系统变化后是否仍有效？
Integrity	Evidence 是否防篡改、可验证、未静默修改？
Independence	生成和评价是否具备风险匹配的独立性？
Limitations	未覆盖和方法弱点是否显式？
Actionability	失败时是否能定位、阻断或触发响应？

10.2 质量结论

建议使用：

ESD-ASSURANCE-001-C14 · 原文代码 / 流程
STRONG
ADEQUATE
LIMITED
INSUFFICIENT
INVALID

不得把这些质量词聚合成一个可以掩盖阻断项的平均分。

ASSUR-REQ-021：Evidence 质量必须与 Claim 关键性匹配

MINOR Claim 可以接受较轻 Evidence；BLOCKING Claim 必须达到足以支持生产裁决的质量。关键性越高，对代表性、独立性、覆盖和完整性的要求越高。

ASSUR-REQ-022：不能只评价执行是否成功

测试框架运行成功、无崩溃或生成报告不等于 Evidence 有效。必须评价测试是否正确、是否命中目标属性、是否使用代表性场景。

11. Evidence Envelope

11.1 标准结构

ESD-ASSURANCE-001-C15 · 原文代码 / 流程

```
evidence:
  evidence_id: "EVD-..."
  title: "..."
  evidence_type: "DESIGN|STATIC|FORMAL|UNIT|PROPERTY|INTEGRATION|SYSTEM|SECURITY|OPERATIONAL|RECOVERY|REVIEW|PROVENANCE"
  related_claims: []
  subject_identity:
    source_commit: "..."
    artifact_digest: "..."
    config_digest: "..."
    schema_policy_model_versions: []
  environment:
    environment_id: "..."
    platform: "..."
    node_or_runtime_spec: "..."
    dependencies: []
  verification:
    activity_id: "..."
    tool: "..."
    tool_version: "..."
    invocation_or_protocol: "..."
    workload_corpus_digest: "..."
    fault_profile: "..."
    started_at: "..."
    completed_at: "..."
  result:
    execution_status: "PASS|FAIL|ERROR|SKIPPED"
    evidence_conclusion: "SUPPORTS|CONTRADICTS|INCONCLUSIVE|NOT_APPLICABLE"
    summary: "..."
  coverage:
    included: []
    excluded: []
    known_limitations: []
  quality:
    relevance: "..."
```

ESD-ASSURANCE-001-C15 · 续

```
representativeness: "..."  
reproducibility: "..."  
independence: "..."  
provenance:  
  producer: "..."  
  artifact_uri: "..."  
  artifact_digest: "..."  
  signature_or_attestation: "..."  
lifecycle:  
  status: "CURRENT|STALE|INVALIDATED|SUPERSEDED|NOT_REPRODUCIBLE"  
  valid_until: "..."  
  invalidation_rules: []  
  supersedes: []  
owner: "..."  
reviewer: "..."
```

ASSUR-REQ-023: Evidence ID 必须稳定且唯一

同一 Evidence ID 不得用于不同执行结果。重复验证应生成新的 Evidence ID，并通过 `supersedes` 或关联字段形成历史链。

ASSUR-REQ-024: 原始制品和摘要必须区分

仪表盘截图、PR 评论或人工摘要不能替代原始日志、报告、数据和 `digest`。摘要可以用于阅读，但必须引用原始 Evidence Artifact。

ASSUR-REQ-025: Evidence 不得只依赖易失链接

用于长期裁决的 Evidence 必须存放在受控、可保留、可验证完整性的系统中。临时 CI URL 到期后，裁决链不能失去依据。

12. 结果状态的严格区分

12.1 Verification Execution Status

状态	含义
PASS	验证活动按定义执行，断言未被违反
FAIL	验证活动执行且发现违反
ERROR	工具、环境或基础设施错误，未得到有效性质结果
SKIPPED	验证未执行或被有意跳过

ERROR 和 SKIPPED 不是 PASS。

12.2 Evidence Conclusion

状态	含义
SUPPORTS	在声明覆盖内为 Claim 提供支持
CONTRADICTS	为 Claim 的违反或关键反例提供证据
INCONCLUSIVE	不能合理支持或反驳 Claim
NOT_APPLICABLE	经论证与该 Claim 无关

一个验证 PASS 仍可能产生 INCONCLUSIVE，例如它只验证了不相关配置。

12.3 Evidence Lifecycle Status

状态	含义
CURRENT	当前仍在声明有效范围内
STALE	时间或环境变化使代表性下降，需要复审
INVALIDATED	已知变化使 Evidence 不再适用
SUPERSEDED	被更新的 Evidence 替代，仍保留历史
NOT_REPRODUCIBLE	无法按声明方法重新产生

12.4 Gate Decision

Gate 状态由 ESD-GOV-001 定义。Evidence 只能支持裁决，不能自行批准生产。

ASSUR-REQ-026：状态不得跨层偷换

以下映射均不成立：

ESD-ASSURANCE-001-C16 · 原文代码 / 流程
Verification PASS -> Gate G0
No alert -> Property PASS
Evidence CURRENT -> System conformant
Test ERROR -> Test PASS
Old benchmark -> Current capacity proven

13. Evidence 生命周期与失效

13.1 生命周期

下图是证据 workflow 阶段，不是 `lifecycle.status` 的另一个枚举；计划、生成、评审和归档由活动记录表达，状态字段只使用 §12.3 的受控值。

ESD-ASSURANCE-001-C17 · 原文代码 / 流程

PLANNED

- > PRODUCED
- > REVIEWED
- > CURRENT
- > STALE / INVALIDATED / SUPERSEDED / NOT_REPRODUCIBLE
- > ARCHIVED

13.2 失效触发

至少以下变化应触发相关 Evidence 复审或失效：

- 源代码、构建器、编译器或依赖变化；
- 配置、Feature Flag、策略或权限变化；
- Schema、协议、模型、Prompt、DBC 或参考数据变化；
- 目标环境、节点规格、内核、区域或存储后端变化；
- 工作负载分布、对象大小、热点或突发超出范围；
- 新故障模式、事故或安全漏洞；
- Evidence 到达 `valid_until`；
- 生成工具被发现存在缺陷；
- 原始 Evidence 无法读取或校验 `digest`。

ASSUR-REQ-027：失效必须传播到 Claim 与 Gate

Evidence 失效后，依赖它的 Claim Conclusion 和未过期 Gate Decision 必须被重新计算。若既无足够支持也无适用反证，Claim 为 UNKNOWN；存在适用反证时保留 CONTRADICTED，Gate 另行重评。

ASSUR-REQ-028：失效规则必须机器可判定或具名负责

能够自动判断的变化应自动失效；无法自动判断的部分必须有 Owner 和复审触发，不能依赖“大家记得”。

13.3 证据时效

时效不只由时间决定。以下二者都可能成立：

- 一年前针对不可变数学模型的证明仍有效；
- 昨天在错误配置上跑出的性能测试已经无效。

因此必须结合对象、环境和变化判断，而不是统一设置固定天数。

14. Verification Plan

14.1 从 Claim 反推验证

Verification Plan 应按以下顺序设计：

ESD-ASSURANCE-001-C18 · 原文代码 / 流程
Claim -> Violation -> Mechanism -> Failure / Input Space -> Verification Method -> Oracle -> Evidence -> Runtime Revalidation

14.2 验证方法选择

目标	适合方法
类型和结构约束	编译器、类型系统、Schema、静态分析
广泛输入性质	Property-based、fuzz、mutation
并发和协议	模型检查、线性化测试、故障注入
边界契约	Contract、integration、mixed-version test
资源上界	压力、soak、限流、故障降容测试
恢复	crash-window、restore、replay、DR 演练
安全	Threat Model、权限负向测试、扫描、渗透
生产适用性	canary、shadow、runtime invariant、SLI

ASSUR-REQ-029: Oracle 必须明确

每项动态验证必须说明如何判断对错。只运行负载而没有正确性 Oracle，只能生成性能观察，不能证明业务性质。

ASSUR-REQ-030: 关键失败窗口必须枚举

对不可逆副作用、提交和 ACK，至少在每个持久化或外部副作用边界前后注入失败，验证恢复和重复语义。

ASSUR-REQ-031: 性能 Evidence 必须使用代表性分布

平均大小和理想输入不足以支撑容量 Claim。应覆盖：

- p50/p95/p99 与硬上限；
- 热点、偏斜和 burst；
- 依赖变慢；
- N-1 或降容；
- 积压恢复；
- retry amplification；
- 目标运行时和硬件。

14.3 负向验证

验证必须尝试推翻 Claim，而不是只证明 happy path。可使用：

- fault injection；
- fuzzing；
- mutation testing；
- invalid/unknown input；
- mixed versions；
- dependency slowdown；
- permission denial；
- clock skew；
- capacity exhaustion；
- operator error；
- stale configuration。

15. 工具与验证器可信度

15.1 工具是保证链的一部分

编译器、测试框架、策略引擎、静态分析器、模型检查器、CI runner 和报告聚合器都可能失败。必须评估：

- 工具适用范围；
- 版本和配置；
- 已知缺陷；
- 失败语义；
- 输出完整性；
- 是否可能被项目绕过；
- 是否需要资格确认或交叉验证。

ASSUR-REQ-032：工具错误必须显式

工具不可用、超时、解析失败或结果不完整必须产生 ERROR / UNKNOWN，不得因“基础设施问题”被转换为通过。

ASSUR-REQ-033：高风险验证规则变更必须受保护

改变测试 Oracle、静态规则、门禁策略、允许列表或报告聚合逻辑可能改变事实裁决，必须经过独立 Review 和回归证据。

15.2 工具资格确认

R3 或高后果性质应考虑：

- 用已知正反样例验证工具；
- 使用两个独立机制交叉检查；
- 固定工具版本和配置；
- 记录工具已知不支持特性；
- 对自研验证器进行单独测试和变更控制；
- 防止项目代码修改验证逻辑后自行获益。

ASSUR-REQ-034：验证器与被验证对象不得共享未经审查的同一错误假设

例如生成器和验证器使用同一错误解析函数，会产生伪独立 Evidence。应尽量使用独立 Oracle、参考实现或差分验证。

16. 覆盖、代表性与采样

16.1 覆盖维度

Coverage 至少可以包括：

ESD-ASSURANCE-001-C19 · 原文代码 / 流程

```
requirements
states and transitions
inputs and distributions
fault windows
versions and combinations
tenants / regions
operating modes
resource boundaries
security actors
recovery paths
```

“代码覆盖率 90%” 只覆盖其中一个弱代理维度。

ASSUR-REQ-035：阻断级 Claim 必须有 Coverage Argument

Coverage Argument 必须说明为何已选择的场景足以支撑 Claim，以及哪些仍未覆盖。

16.2 代表性

代表性应基于真实或有依据的目标分布，包括：

- 生产 telemetry；
- 历史事故；
- 数据样本分析；
- 明确容量预测；
- 合同或业务上限；
- 攻击模型；
- 故障域。

只挑选最干净样本会高估系统能力。

16.3 采样边界

生产采样 Evidence 必须说明：

- 采样率；
- 漏失偏差；
- 高基数控制；
- 时钟和聚合误差；
- 隐私处理；
- 异常数据是否被过滤；
- 结果能否代表全量。

ASSUR-REQ-036：未观测到违反不等于违反不存在

运行指标没有出现错误，只能支持“在当前观测能力和样本中未发现”，不能证明全局 Safety。需要结合 invariant、审计、负向测试和检测覆盖。

17. 组合保证

17.1 组合问题

局部组件 Evidence 组合时常见断裂：

- 版本不同；
- 配置不同；
- 上下游 Assumption 不匹配；
- 边界错误语义未测试；
- 单组件容量足够但端到端排队失稳；
- mixed-version deployment 未覆盖；
- 共享依赖导致故障相关性；
- 局部幂等不等于端到端 exactly-once effect。

17.2 组合检查

ESD-ASSURANCE-001-C20 · 原文代码 / 流程

```
For each boundary A -> B:  
  Guarantee(A) satisfies Assumption(B)  
  Error semantics are compatible  
  Capacity and backpressure are compatible  
  Identity and version are preserved  
  Failure correlation is modeled
```

ESD-ASSURANCE-001-C20 · 续

Combined evidence refers to the same release composition

ASSUR-REQ-037: Release Composition 必须唯一标识

Evidence Bundle 必须说明服务、配置、Schema、模型、依赖和环境的完整组合。不能将不同时间、不同候选版本的最佳结果拼成一份虚构发布证据。

ASSUR-REQ-038: 混合版本窗口必须进入论证

滚动升级、回滚和灰度期间的版本组合是生产真实状态，必须明确兼容保证和 Evidence。

18. Assurance Case 充分性

18.1 充分性不是绝对证明

“充分”表示：在当前风险等级、Claim 关键性、对象范围和决策类型下，Argument 和 Evidence 足以支持授权主体作出有边界的决策。

18.2 最低判据

一个 Decision-grade Assurance Case 至少满足：

- Top-level Claim 具有类型匹配的验证义务与违反语义；
- Claim 分解覆盖主要状态、边界和故障；
- 关键 Assumption 分别登记验证、生命周期和监测状态；监测不替代验证，证据不足显式保持未知；
- Evidence 与当前对象绑定；
- 证据质量和代表性与风险匹配；
- Counterevidence 和 Defeater 已处理；
- 组合边界已论证；
- Evidence 当前有效；
- 剩余风险、未知和例外明确；
- Decision Authority 在授权范围内。

18.3 按风险等级

风险	Assurance 最低深度
R0	可逆实验假设、数据边界、硬上限和退出证据
R1	关键 Claim、基础动态 Evidence、Owner Review、生产观察
R2	完整 Assurance Matrix、多样 Evidence、代表性环境、故障与恢复验证
R3	独立评价、Defeater Register、工具资格、组合保证、持续漂移与严格证据完整性

ASSUR-REQ-039：不得用总分掩盖阻断项

Assurance Case 不得通过加权平均、总体通过率或“风险分数低”覆盖单个未解决的阻断级 Safety、Security 或 Recovery Claim。

19. Evidence Conclusion 与 Claim Status

19.1 Claim Status

建议使用：

状态	含义
SUPPORTED	当前 Argument 与 Evidence 足以支持声明范围内的 Claim
CONDITIONALLY_SUPPORTED	仅在明确限定的前提、对象或范围内有充分 Argument 与 Evidence 支持；该限定须作为 Claim 的可审计组成部分
CONTRADICTED	存在足以反驳 Claim 的 Evidence
UNKNOWN	Evidence 或 Argument 不足
NOT_APPLICABLE	经论证与当前对象无关

Exception 只授权接受偏离/风险，不增加事实支持；Change Envelope 只限制暴露，也不自动补齐证据。缩小范围或增加前提以挽救主张时，必须生成明确的 Claim 修订版本或新 ID，重新绑定 Evidence，并保留原 Claim 的状态与历史反证。

三个维度必须分别记录：Claim 支持状态（本章）、要求满足事实与 Exception 授权（GOV §10）、发布裁决（GOV §8）。它们不存在自动升格映射。

反例校准（说明性，非真实演练记录）：原 Claim 声明“恢复 ≤30 分钟”，适用演练结果为 45 分钟。即使有效 Exception 接受了风险，原 Claim 仍为 CONTRADICTED；要求满足事实仍为 NONCONFORMANT。授权范围允许时 Gate 可另判 CONDITIONAL_GO，不可豁免或超出授权时为 NO_GO。若改为“恢复 ≤60 分钟”，须显式修订 Claim，并审查 45 分钟 Evidence 是否足以支持其完整作用域，而非仅比较两个数字。

19.2 状态传播

ESD-ASSURANCE-001-C21 · 原文代码 / 流程
Blocking subclaim CONTRADICTED -> parent claim cannot be SUPPORTED
Blocking subclaim UNKNOWN -> parent claim usually UNKNOWN
Evidence INVALIDATED -> dependent claim recomputed
Assumption validation_status VIOLATED -> reassess dependent claim and its scope

假设失效可能使原论证不再适用，但并非自动构成所有依赖 Claim 的反例。已有适用反证时保留 CONTRADICTED；只有不能支持且不能反驳时才记 UNKNOWN。阻断级 Defeater 被风险接受不等于已被反驳或消除，不能因此提高 Claim 支持状态。

ASSUR-REQ-040：父 Claim 状态必须可解释

任何聚合结论必须能够追溯到子 Claim、Evidence 和传播规则。不得只显示绿色总览而隐藏阻断来源。

20. Gate 与发布裁决

20.1 Evidence Review 输出

Assurance Reviewer 应输出：

ESD-ASSURANCE-001-C22 · 原文代码 / 流程
<pre>assurance_review: review_id: "AR-..." subject_identity: "..." claims_reviewed: [] supported: [] conditional: [] contradicted: [] unknown: [] stale_or_invalid_evidence: [] open_defeaters: [] residual_risks: [] conclusion: "DECISION_GRADE NOT_DECISION_GRADE PARTIALLY_DECISION_GRADE" scope: "..." reviewer: "..." reviewed_at: "..."</pre>

20.2 Gate 决策

Gate 决策必须引用 Assurance Review，而不是复制测试列表。Decision Authority 负责接受剩余风险，Assurance Reviewer 负责评价证据充分性，两者职责不同。

ASSUR-REQ-041：Assurance Reviewer 不自动拥有风险接受权

证据评价结论 DECISION_GRADE 只表示可以作出决策，不表示必须 GO。业务、运营、安全和残余风险仍由授权 Decision Authority 裁决。

ASSUR-REQ-042：Decision Authority 不得改写证据事实

Decision Authority 可以在授权范围接受风险或批准 Exception，但不能把 FAIL、CONTRADICTS 或失效 Evidence 修改为 PASS，也不能据此把 CONTRADICTED/UNKNOWN Claim 改为 SUPPORTED/CONDITIONALLY_SUPPORTED。证据事实、Claim 支持状态、要求满足事实、Exception 授权与 Gate 决策必须分开记录并关联。

21. Release Evidence Bundle

21.1 目标

Release Evidence Bundle 是对一次具体生产候选的证据封装。它必须可独立回答：

- 发布的究竟是什么；
- 依赖哪些配置和外部版本；
- 哪些 Claim 得到支持；
- 哪些未知和例外仍存在；
- 证据从哪里产生；
- 允许多大生产暴露；
- 什么情况立即停止。

21.2 最低内容

ESD-ASSURANCE-001-C23 · 原文代码 / 流程

```
release-manifest.yaml
subject-identity.json
claim-status.json
assurance-case.md or structured representation
evidence-index.json
verification reports
capacity and recovery evidence
security evidence
```

ESD-ASSURANCE-001-C23 · 续

```
exceptions.yaml
residual-risks.md
change-envelope.yaml
approvals.yaml
sha256sums.txt
```

ASSUR-REQ-043: Bundle 必须防止证据混淆

Bundle 必须通过 manifest 和 digest 关联所有关键文件。不能从多个候选中挑选最优结果后组成发布包。

ASSUR-REQ-044: Bundle 必须包含失败和限制

失败测试、被接受的 Defeater、UNKNOWN、Exception 和未覆盖范围必须进入 Bundle，而不是只包含通过材料。

ASSUR-REQ-045: Bundle 必须可长期验证

至少应保留：

- 生成时间；
- 工具和环境身份；
- 原始 Artifact digest；
- Evidence digest；
- 签名或不可篡改证明；
- 决策主体；
- 保留策略。

22. Change Envelope

22.1 Assurance 视角

Change Envelope 将 Evidence 覆盖转化为生产暴露边界：

ESD-ASSURANCE-001-C24 · 原文代码 / 流程

```
change_envelope:
  subject_identity: "...
  population: "...
  traffic_or_data_scope: "...
  max_duration: "...
```

ESD-ASSURANCE-001-C24 · 续

```
max_concurrency_or_bytes: "..."  
preconditions: []  
success_criteria: []  
observation_signals: []  
abort_conditions: []  
rollback_or_forward_recovery: "..."  
owner: "..."  
authority: "..."
```

ASSUR-REQ-046: 暴露不得超出 Evidence 范围

如果容量只在某节点规格和 $2\times$ 峰值下验证，Change Envelope 不得直接授权更大规模。扩大范围须补足相应 Evidence；若按 GOV 授权程序临时接受未覆盖风险，应另记 Exception、未知范围和条件裁决，不得声称扩大范围内的 Claim 已获支持。

ASSUR-REQ-047: 停止条件必须对应关键性质

Canary 的自动停止条件应包括关键正确性、资源和安全违反，而不只是错误率或延迟。

23. 运行时持续保证

23.1 Runtime Evidence

运行时可以提供：

- invariant violation；
- queue depth/age；
- resource bound；
- duplicate/conflict；
- provenance mismatch；
- assumption drift；
- error budget；
- recovery progress；
- permission/audit event；
- mixed-version state。

ASSUR-REQ-048：运行监测必须映射到 Claim 或 Assumption

“监控很多”不是持续保证。每个关键运行信号应说明它验证、挑战或失效哪个 Claim/Assumption，以及触发什么动作。

23.2 Drift

Drift 可以来自：

ESD-ASSURANCE-001-C25 · 原文代码 / 流程
artifact drift
configuration drift
environment drift
dependency drift
workload drift
schema/model/reference-data drift
organizational ownership drift

ASSUR-REQ-049：Drift 必须触发结论降级

一旦运行对象超出 Evidence Envelope，相关 Claim 不能仅凭旧 Evidence 继续显示 SUPPORTED。系统应自动或由 Owner 按 §19 重评：不足以支持且无适用反证时为 UNKNOWN，已有适用反证时为 CONTRADICTED，并触发再验证或限制暴露。

23.3 Continuous Assurance

持续保证不是每次提交都执行所有昂贵验证，而是建立分层策略：

ESD-ASSURANCE-001-C26 · 原文代码 / 流程
per-change deterministic checks
per-merge integration checks
scheduled system / fault / recovery checks
pre-release decision-grade evidence
runtime drift and invariant monitoring
incident-triggered revalidation

24. Incident → Assurance Delta

24.1 事故作为反证

事故和近失事件必须被视为 Counterevidence，而不仅是运维事件。它可能表明：

- Claim 定义错误；
- Assumption 未显式；
- Failure Model 不完整；
- Mechanism 无效；
- Verification 漏掉关键窗口；
- Evidence 代表性不足；
- Gate 或 Exception 失效；
- 运行监测无法及时检测。

ASSUR-REQ-050：重大事故必须产生 Assurance Delta

至少改变以下一项：

ESD-ASSURANCE-001-C27 · 原文代码 / 流程
Claim / Property Assumption Argument Mechanism Verification Activity Evidence Requirement Runtime Signal Exception / Authority Runbook / Recovery Standard / Profile

24.2 Delta 结构

ESD-ASSURANCE-001-C28 · 原文代码 / 流程
assurance_delta: incident_id: "..." affected_claims: [] counterevidence: [] invalidated_evidence: [] newly_discovered_assumptions: [] argument_gaps: [] required_changes: [] owners: []

ESD-ASSURANCE-001-C28 · 续

```
closure_evidence: []  
standard_impact: "..."
```

ASSUR-REQ-051：事故关闭不得只依赖文字提醒

如果没有改变控制、验证、证据、权限、容量或恢复能力，系统通常没有获得可验证的抵抗力提升。

25. Assurance Plane 元不变量

ASSUR-REQ-052：缺失或错绑 Evidence 不得为通过

这是保证面的最高元不变量。

ASSUR-REQ-053：用于裁决的 Evidence 不得静默修改

修改必须产生新 Evidence ID 和完整历史。

ASSUR-REQ-054：门禁规则和 Exception 逻辑必须版本化

每次裁决必须能够说明使用了哪一版规则。

ASSUR-REQ-055：高风险裁决必须保留职责分离

Proposer、Evaluator 和 Final Approver 的独立性必须符合 ESD-GOV-001。

ASSUR-REQ-056：Assurance Plane 不可用不得默认放行

对 R2/R3，验证服务、策略引擎、Evidence Store 或身份链不可用时，默认结果为 UNKNOWN / NO RELEASE QUALIFICATION。

ASSUR-REQ-057：例外必须进入 Evidence Bundle

不得在 Bundle 之外通过口头、聊天或临时配置隐藏偏离。

ASSUR-REQ-058：运行漂移必须使证据结论失效

不能让监控发现对象已变化，而发布面仍显示历史绿色状态。

26. 角色与独立性

26.1 角色

角色	责任
Claim Owner	定义并维护 Claim 及违反语义
Evidence Producer	执行验证并生成原始 Evidence
Evidence Custodian	保证存储、完整性、保留和访问
Assurance Author	构建 Argument 和 Evidence 映射
Assurance Reviewer	挑战充分性、Defeater、覆盖和时效
Decision Authority	接受剩余风险并作 Gate 决策
Tool Owner	维护验证器能力、版本和已知限制
Operational Owner	维护 Runtime Evidence 和 drift 响应

ASSUR-REQ-059：Evidence Producer 与 Reviewer 的独立性风险匹配

R3 阻断级 Claim 不应仅由实现作者自产生并自评价全部 Evidence。可以共享技术知识，但必须存在独立挑战和最终批准。

ASSUR-REQ-060：Assurance Author 不得隐藏不利材料

Assurance Case 必须包含 open Defeater、Counterevidence、已知缺陷和 Evidence 限制。

27. 常见反模式

27.1 Test List as Assurance Case

症状：列出数百个测试，却没有 Claim、作用域和覆盖论证。
校正：从阻断级 Claim 反推验证与 Evidence。

27.2 Green Dashboard Fallacy

症状：所有 CI 绿色，因此认为系统整体安全。

校正：明确哪些性质未编码、哪些 Evidence 已过期或局部化。

27.3 Evidence Shopping

症状：从多个候选中选最优性能报告，忽略失败候选。

校正：Bundle 绑定唯一 Release Composition，并保留失败历史。

27.4 Old Evidence, New System

症状：用旧环境或旧版本测试支持当前发布。

校正：Subject Binding 和自动失效。

27.5 Local Pass, Global Claim

症状：组件测试通过，被提升为端到端 exactly-once。

校正：Assume-Guarantee 与组合 Evidence。

27.6 No Incident Means Safe

症状：线上无事故被解释为性质已证明。

校正：评估检测覆盖、样本量、暴露和未观测风险。

27.7 Exception Hidden Outside the Case

症状：正式报告全绿，实际风险只存在聊天记录。

校正：Exception、Unknown 和 Residual Risk 必须进入 Bundle。

27.8 Tool Authority Inflation

症状：把静态分析器、LLM Reviewer 或策略引擎当作绝对仲裁者。

校正：声明工具覆盖、已知限制、失败语义和人工挑战边界。

27.9 Confidence Score Theater

症状：用 92% “可信度” 掩盖阻断级未知。

校正：逐 Claim 状态和 Defeater；不以总分覆盖硬阻断。

27.10 Evidence Never Expires

症状：一次压测长期支撑任意规模和环境。
校正：Evidence Envelope、valid range 和 drift invalidation。

28. Assurance Case 模板

ESD-ASSURANCE-001-C29 · 原文代码 / 流程

```
# Assurance Case AC-XXX

## 1. Subject

- System / Change:
- Risk tier:
- Source commit:
- Artifact digest:
- Config digest:
- Environment:
- Change Envelope:

## 2. Top-level Claim

### CLM-001

- Statement:
- Type:
- Scope:
- Temporal semantics:
- Assumptions:
- Violation:
- Criticality:
- Owner:

## 3. Argument Strategy

Explain why the following subclaims are jointly sufficient.

## 4. Subclaims

| Claim ID | Statement | Status | Evidence | Defeaters |
|---|---|---|---|---|

## 5. Assumptions
```

ESD-ASSURANCE-001-C29 · 续

	Assumption ID		Statement		Validation		Lifecycle		Monitoring		Risk Flag	
Evidence		Runtime Signal		Violation Response								
---	---	---	---	---	---	---	---	---	---	---	---	

6. Mechanisms

7. Verification Activities

8. Evidence Index

	Evidence ID		Type		Conclusion		Lifecycle		Subject Binding		Limitations	
---	---	---	---	---	---	---	---	---	---	---	---	

9. Counterevidence and Defeaters

10. Coverage Argument

11. Composition Argument

12. Residual Risks and Unknowns

13. Assurance Review

14. Decision and Scope

15. Invalidation and Review Triggers

29. Verification & Evidence Matrix 模板

下列行仅示范字段关联，不代表存在已执行测试或当前有效证据；项目须以真实记录替换。

表 16 · 字段记录视图（列名与原单元格逐项对应）

ESD-ASSURANCE-001-T16 / 记录 1	
Property / Claim	
CP-001	
Mechanism	
Conditional commit	
Verification	
Crash-window test	
Oracle	
Single manifest per identity	

ESD-ASSURANCE-001-T16 / 记录 1 · 续
Environment / Corpus Target-like
Evidence ID EVD-001
Conclusion SUPPORTS
Lifecycle CURRENT
Limitations No region partition
Owner Team A

30. Evidence Review Checklist

Claim

- ☐ Claim 的验证义务与 Safety、活性或统计性质匹配；
- ☐ 主体、身份、版本、模式和时间语义明确；
- ☐ 违反条件和后果明确；
- ☐ Criticality 与风险匹配；
- ☐ Assumption 和允许降级已列出。

Argument

- ☐ 分解策略合理；
- ☐ 子 Claim 共同足以支持父 Claim；
- ☐ 状态、边界、故障和混合版本未遗漏；
- ☐ Defeater 和替代解释已挑战；
- ☐ 组合保证成立。

Evidence

- ☐ 与当前对象不可混淆地绑定；
- ☐ 方法与 Claim 相关；
- ☐ Oracle 明确；
- ☐ 代表性和覆盖可接受；
- ☐ 原始 Artifact 可访问并校验；

- ☐ 工具版本和限制明确；
- ☐ 生命周期为 CURRENT；
- ☐ Counterevidence 未被隐藏。

Decision

- ☐ 阻断级未知未被平均分掩盖；
- ☐ Assurance Reviewer 与 Decision Authority 职责分开；
- ☐ Residual Risk 有授权 Owner；
- ☐ Change Envelope 不超出 Evidence 范围；
- ☐ 结论有失效规则和复审触发。

31. Release Evidence Bundle Manifest 示例

ESD-ASSURANCE-001-C30 · 原文代码 / 流程

```
release_evidence_bundle:
  bundle_id: "REB-2026-001"
  suite_version: "<adopted-suite-version>"
  subject_identity:
    source_commit: "..."
    artifact_digest: "..."
    config_digest: "..."
    environment: "..."
  assurance_case: "AC-001"
  claims:
    supported: []
    conditional: []
    contradicted: []
    unknown: []
  evidence_index: "evidence-index.json"
  exceptions: []
  residual_risks: []
  change_envelope: "change-envelope.yaml"
  reviewers: []
  decision_authority: "..."
  decision: "GO|CONDITIONAL_GO|NO_GO|UNKNOWN"
  produced_at: "..."
  invalidation_rules: []
  files:
    - path: "..."
      sha256: "..."
```

32. 最终判定标准

一个 Assurance Case 只有在能够回答以下问题时，才具备支持高质量裁决的基础：

1. 主张针对哪个不可混淆对象？
2. 主张到底声称什么，需要哪类验证、反驳或统计评价，观测边界在哪里？
3. 主张依赖哪些 Assumption，它们当前是否成立？
4. 论证如何把系统级主张分解为可验证子主张？
5. 机制为何能够维护这些性质？
6. 验证是否覆盖关键状态、边界、故障和混合版本？
7. Evidence 是否代表目标环境和真实工作负载？
8. Evidence 是否绑定当前制品、配置和依赖？
9. 工具、Oracle 和验证器是否可信且失败语义明确？
10. 有哪些 Counterevidence、Defeater 和已知限制？
11. 局部 Evidence 如何组合成端到端保证？
12. 哪些 Claim 仍为 UNKNOWN，是否阻断？
13. 谁评价 Evidence，谁接受 Residual Risk？
14. Change Envelope 是否超出已验证范围？
15. 什么变化会使结论失效，系统如何检测该变化？
16. 事故发生后 Assurance Case 如何增长？

结论

工程保证的成熟标志不是“我们拥有更多绿色报告”，而是团队能够对每项关键结论给出一条诚实、可挑战、可失效、可复现的推理链。真正可信的 Assurance Case 会同时展示支持、限制、反证和未知，并把最终决定严格绑定到当前对象和授权范围。